CONFIDENTIAL // SECURITY ASSESSMENT REPORT

Vulnerability Assessment & Penetration Testing (VAPT) Report

Engagement: **[DEMO DATA] Juice Shop Lab**

Target Infrastructure:	127.0.0.1
Engagement Scope:	Local Juice Shop training app on localhost
Assessment Status:	Approved // APPROVED
Lead Analyst:	SentinelVAPT Autonomous Engine (Human Lead Sign-off Recorded)
Report Generated At:	2026-11-07 11:06:13 UTC
Evidentiary Hash Chain:	SHA-256 Ledger: 49 verified blocks

Important Notice: *This security report contains proprietary technical findings and evidence gathered during an authorized vulnerability assessment. All findings originate from genuine scanner artifacts; AI text is explanatory and grounded in observed data. Distribution is restricted to authorized personnel.*

Table of Contents

7.1	Executive Summary & Scope Statement
7.2	Methodology, Rules of Engagement & Asset Inventory
7.3	Vulnerability Distribution & Risk Prioritization Matrix
7.4	Detailed Technical Findings & Evidence Traces
7.5	Business & Technical Impact + Actionable Remediation
7.6	Limitations, Assumptions, Failures & Human Approval Log
Appendix A	Truthful Integration & Adapter Capability Matrix
Appendix B	Cryptographic Audit Ledger & Integrity Verification

7.1 Executive Summary & Scope Statement

SentinelVAPT conducted an authorized security assessment against **127.0.0.1**. A total of **8** unique vulnerabilities were identified and corroborated across multiple scanning tools. Identified flaws include **0 Critical**, **0 High**, **1 Medium**, **2 Low**, and **5 Informational** items. Every finding presented in this document has been verified against raw machine artifacts with cryptographic hash verification.

Authorized Scope:	Local Juice Shop training app on localhost
Deterministic Gate:	ENFORCED. All public IPv4/IPv6 ranges strictly blocked by default; zero out-of-scope egress.
Authorization Stmt:	I own / am authorized to test this lab system.

7.2 Methodology & Rules of Engagement

The assessment followed the structured penetration testing guidelines defined in **NIST SP 800-115** (Technical Guide to Information Security Testing and Assessment) and **OWASP Web Security Testing Guide (WSTG)**. *Disclaimer: Reference to these standards indicates methodological alignment only and does not establish formal third-party compliance certification.*

Assets Tested: 127.0.0.1, http:

7.3 Severity Distribution & Prioritized Risk Matrix

#	Vulnerability Title	Severity	CVSS	Risk Score	Evidence ID
1	Missing Anti-CSRF Tokens (sample import)	MEDIUM	5.0	**4.50**	`EVID-DD477CFF`
2	Cross Domain Misconfiguration (sample import)	LOW	2.5	**2.25**	`EVID-DD477CFF`
3	Missing security headers (demo)	LOW	2.5	**2.12**	`EVID-DEMO`
4	Open port 3000 (demo)	INFO	0.0	**0.00**	`EVID-DEMO`
5	/admin/ - user and password.	INFO	0.0	**0.00**	`EVID-5420CD94`

#	Vulnerability Title	Severity	CVSS	Risk Score	Evidence ID
6	OPTIONS: HTTP method TRACE methodology appears to be supported on	INFO	0.0	**0.00**	EVID-5420CD94
7	Open port 80/http	INFO	0.0	**0.00**	EVID-486EE589
8	Open port 3000/http	INFO	0.0	**0.00**	EVID-486EE589

7.4 Detailed Technical Findings & Evidence Traces

#1: Missing Anti-CSRF Tokens (sample import)

Severity:	**MEDIUM** (CVSS 5.0)	**Risk Score:**	**4.5** / 10.0
Affected Asset:	http: http://127.0.0.1:3000/#/profile	**Status:**	**SUSPECTED** (90% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	CWE-352
Source Tool:	zap	**Evidence Trace ID:**	**EVID-DD477CFF**

OBSERVED EVIDENCE (Raw Scanner Output):

```
Form found without CSRF token (SAMPLE file — not a live scan result).
```

[AI INFERENCE — 90% Confidence — Evidence Ref: EVID-DD477CFF]
Risk Explanation: risk = CVSS 5.0 × confidence 0.9 = 4.5 (severity=medium)

Actionable Remediation: Add anti-CSRF tokens to all state-changing forms.

#2: Cross Domain Misconfiguration (sample import)

Severity:	**LOW** (CVSS 2.5)	**Risk Score:**	**2.25** / 10.0
Affected Asset:	http: http://127.0.0.1:3000/	**Status:**	**SUSPECTED** (90% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	CWE-942
Source Tool:	zap	**Evidence Trace ID:**	**EVID-DD477CFF**

OBSERVED EVIDENCE (Raw Scanner Output):

```
Access-Control-Allow-Origin: * (SAMPLE file — not a live scan result).
```

[AI INFERENCE — 90% Confidence — Evidence Ref: EVID-DD477CFF]
Risk Explanation: risk = CVSS 2.5 × confidence 0.9 = 2.25 (severity=low)

Actionable Remediation: Restrict CORS to trusted origins.

#3: Missing security headers (demo)

Severity:	**LOW** (CVSS 2.5)	**Risk Score:**	**2.12** / 10.0
Affected Asset:	127.0.0.1 http://127.0.0.1:3000	**Status:**	**SUSPECTED** (85% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	demo	**Evidence Trace ID:**	**EVID-DEMO**

OBSERVED EVIDENCE (Raw Scanner Output):

```
X-Content-Type-Options header not set (DEMO DATA — not a real scan result).
```

[AI INFERENCE — 85% Confidence — Evidence Ref: EVID-DEMO]
Risk Explanation: risk = CVSS 2.5 × confidence 0.85 = 2.12 (severity=low)

Actionable Remediation: Add Content-Security-Policy and related headers.

#4: Open port 3000 (demo)

Severity:	**INFO** (CVSS 0.0)	**Risk Score:**	**0.0** / 10.0
Affected Asset:	127.0.0.1 127.0.0.1:3000	**Status:**	**SUSPECTED** (100% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	demo	**Evidence Trace ID:**	**EVID-DEMO**

OBSERVED EVIDENCE (Raw Scanner Output):

```
port 3000 open (DEMO DATA — not a real scan result).
```

[AI INFERENCE — 100% Confidence — Evidence Ref: EVID-DEMO]
Risk Explanation: risk = CVSS 0.0 × confidence 1.0 = 0.0 (severity=info)

Actionable Remediation: Review port exposure; restrict via firewall.

#5: /admin/ - user and password.

Severity:	**INFO** (CVSS 0.0)	**Risk Score:**	**0.0** / 10.0
Affected Asset:		**Status:**	**SUSPECTED** (60% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	nikto	**Evidence Trace ID:**	**EVID-5420CD94**

OBSERVED EVIDENCE (Raw Scanner Output):

```
+ /admin/ - user and password.
```

[AI INFERENCE — 60% Confidence — Evidence Ref: EVID-5420CD94]
Risk Explanation: risk = CVSS 0.0 × confidence 0.6 = 0.0 (severity=info)

Actionable Remediation: Review Nikto output; patch/upgrade the identified component.

#6: OPTIONS: HTTP method TRACE methodology appears to be supported on this server. Method TRACE may allow XST attacks.

Severity:	**INFO** (CVSS 0.0)	**Risk Score:**	**0.0** / 10.0
Affected Asset:		**Status:**	**SUSPECTED** (60% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	nikto	**Evidence Trace ID:**	**EVID-5420CD94**

OBSERVED EVIDENCE (Raw Scanner Output):

```
+ OPTIONS: HTTP method TRACE methodology appears to be supported on this server. Method TRACE may allow XST
attacks.
```

[AI INFERENCE — 60% Confidence — Evidence Ref: EVID-5420CD94]
Risk Explanation: risk = CVSS 0.0 × confidence 0.6 = 0.0 (severity=info)

Actionable Remediation: Review Nikto output; patch/upgrade the identified component.

#7: Open port 80/http

Severity:	**INFO** (CVSS 0.0)	**Risk Score:**	**0.0** / 10.0
Affected Asset:	127.0.0.1 127.0.0.1:80	**Status:**	**SUSPECTED** (100% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	nmap	**Evidence Trace ID:**	**EVID-486EE589**

OBSERVED EVIDENCE (Raw Scanner Output):

```
port 80 state=open service=http
```

[AI INFERENCE — 100% Confidence — Evidence Ref: EVID-486EE589]
Risk Explanation: risk = CVSS 0.0 × confidence 1.0 = 0.0 (severity=info)

Actionable Remediation: Review exposure; close unnecessary ports; apply firewall rules.

#8: Open port 3000/http

Severity:	**INFO** (CVSS 0.0)	**Risk Score:**	**0.0** / 10.0
Affected Asset:	127.0.0.1 127.0.0.1:3000	**Status:**	**SUSPECTED** (100% confidence)
CVE Identifier:	Not assigned	**CWE Classification:**	Not classified
Source Tool:	nmap	**Evidence Trace ID:**	**EVID-486EE589**

OBSERVED EVIDENCE (Raw Scanner Output):

```
port 3000 state=open service=http
```

[AI INFERENCE — 100% Confidence — Evidence Ref: EVID-486EE589]
Risk Explanation: risk = CVSS 0.0 × confidence 1.0 = 0.0 (severity=info)

Actionable Remediation: Review exposure; close unnecessary ports; apply firewall rules.

7.5 Business & Technical Impact

Technical Impact: Vulnerabilities identified in this assessment pose risks ranging from unauthorized reconnaissance and information disclosure to potential remote command execution and service disruption.

Business Impact: Unmitigated high and critical findings could allow an adversary to pivot into internal network segments, compromise client data, violate regulatory privacy controls, or disrupt availability.

7.6 Limitations, Assumptions & Human Approval Log

Assessment Limitations & Scope Boundary Conditions:
1. Active denial-of-service (DoS) tests were strictly excluded from the rules of engagement.
2. All scanning was constrained to organizer-provided lab networks; public egress was blocked.
3. Live scanning of commercial products (Nessus, Burp Pro) is import-only to respect software licenses.
4. Any offensive exploitation attempts require explicit prior human analyst approval.

Recorded Human Approvals & Checkpoints:

ID	Type	Approver	Target	Status	Timestamp (UTC)
APPR-INIT	Assessment Authorization	Lead Analyst	127.0.0.1	**APPROVED**	2026-11-06 10:08:48

Appendix: Cryptographic Audit Ledger Verification

Audit Status:	**VERIFIED INTACT // UNTAMPERED**
Total Chained Blocks:	4
Hash Algorithm:	SHA-256 with sequential prev_hash cryptographic chaining